

HINT 365 · Compliance dossier

EU GDPR · Swiss FADP · ePrivacy · MDR boundary — reviewed 2026-10-02 · terms version 22. Self-assessment by the developer for the owner; not legal advice. Source: docs/compliance/gdpr.md. Statuses: compliant, partial, open.

8 compliant · 6 partial · 5 open, out of 19 controls.

C01	Lawful basis	Compliant
C02	Transparency	Open
C03	Minimisation	Compliant
C04	Storage limitation	Compliant
C05	Security in transit	Compliant
C06	Security at rest	Partial
C07	Data location	Partial
C08	Transfers outside EU/CH	Partial
C09	Processors	Open
C10	Rights: access and portability	Partial
C11	Rights: erasure	Compliant
C12	Records	Partial
C13	Impact assessment	Open
C14	Breach procedure	Open
C15	EU representative	Open
C16	Cookies	Compliant
C17	Privacy by design	Compliant
C18	Medical device boundary	Partial
C19	Vulnerability management	Compliant

C01 Lawful basis

Compliant

Requirement	Health data processed only with explicit consent
Law	GDPR Art. 9(2)(a), 7 · FADP Art. 6(7)
Evidence	Consent at sign-in and a separate health-data consent; terms v17 accepted and recorded (acceptances, text fingerprint)
Source document	docs/compliance/gdpr.md

Where it is declared to users

Terms of use, version 22 (English) · section “Availability, responsibility and acceptance” · also at /terms The service may have outages and require updates. Unsupported app versions may be disabled for security. Nothing in these terms excludes statutory rights or the provider’s mandatory responsibilities. You can delete individual records or your account in the app, and exercise the rights explained in the privacy policy. You can download these terms as a PDF from the app, with the button at the end of the text, and keep them. By accepting, you confirm you are at least 18 and agree to these terms. Consent to storing your health data is requested separately and can be withdrawn by deleting your account. Acceptance and health-data consent are recorded with account, document version, language, text hash, app version and time.
Terms of use, version 22 (English) · section “Account, storage and providers” · also at /terms Sign in with Google uses OAuth 2.0/OpenID Connect. HINT 365 does not receive your Google password. The server stores an HMAC of your Google account identifier, not your email. Confirmed pressure readings are stored with your account in Cloudflare D1 in the EU for up to 365 days and purged daily; lab results stay until you delete them (never automatically). Both they are pseudonymized, not anonymous. Google recovery reconnects your synchronized history. Blood pressure is recorded by voice or with a photo of the monitor. The phone’s speech service may use its own network processing. The photo Scan reads the monitor display with artificial intelligence. The Scan is an AI feature: it is on at once, free for 15 days from the first Scan, then with the AI features subscription; in every case at most 3 Scans a day. The trial is given once per Google account and per phone: for this the server keeps an HMAC fingerprint of the Google account and of the phone’s identifier with the trial start date, also after the account is deleted, for at most 2 years and only for this purpose. The photo of the display goes through HINT 365’s server to Anthropic (Claude), which reads the three numbers for HINT 365 and does not use them to train its models; the server passes the photo on without storing or logging it, and the photo carries no name or account. In every case the numbers read are shown to you and saved only if you confirm them, and the photo is then deleted from the phone. Only the three numbers you confirmed are stored by HINT 365. Acceptance records (pseudonymous account code, HMAC fingerprints of the Google account and of the phone, version, language and fingerprint of the text, date; never the email) are retained as evidence also after account deletion, with a backup copy in a second database in the EU; technical error codes are retained for 90 days without free-text messages. Details and rights are described in the privacy policy. The web uses only the technical session cookie hint_s (seven days) and the stored cookie choice; Android uses no cookies.

C02 Transparency [Open](#)

Requirement	Privacy notice names the controller (name, address, contact)
Law	GDPR Art. 13(1)(a) · FADP Art. 19
Evidence	Gap G1: the owner's name and postal address are missing
Next step	Human gives name/business name and address
Source document	docs/compliance/gdpr.md

Not declared to users: an internal control, still open.

C03 Minimisation Compliant

Requirement	Only the data needed: no name, no email, no documents
Law	GDPR Art. 5(1)(c) · FADP Art. 6(3)
Evidence	Google account as HMAC only; lab documents never leave the phone; only report date and values as printed; logs without values
Source document	docs/compliance/gdpr.md

Where it is declared to users

Terms of use, version 22 (English) · section “Account, storage and providers” · also at /terms

Sign in with Google uses OAuth 2.0/OpenID Connect. HINT 365 does not receive your Google password. The server stores an HMAC of your Google account identifier, not your email. Confirmed pressure readings are stored with your account in Cloudflare D1 in the EU for up to 365 days and purged daily; lab results stay until you delete them (never automatically). Both they are pseudonymized, not anonymous. Google recovery reconnects your synchronized history. Blood pressure is recorded by voice or with a photo of the monitor. The phone's speech service may use its own network processing. The photo Scan reads the monitor display with artificial intelligence. The Scan is an AI feature: it is on at once, free for 15 days from the first Scan, then with the AI features subscription; in every case at most 3 Scans a day. The trial is given once per Google account and per phone: for this the server keeps an HMAC fingerprint of the Google account and of the phone's identifier with the trial start date, also after the account is deleted, for at most 2 years and only for this purpose. The photo of the display goes through HINT 365's server to Anthropic (Claude), which reads the three numbers for HINT 365 and does not use them to train its models; the server passes the photo on without storing or logging it, and the photo carries no name or account. In every case the numbers read are shown to you and saved only if you confirm them, and the photo is then deleted from the phone. Only the three numbers you confirmed are stored by HINT 365. Acceptance records (pseudonymous account code, HMAC fingerprints of the Google account and of the phone, version, language and fingerprint of the text, date; never the email) are retained as evidence also after account deletion, with a backup copy in a second database in the EU; technical error codes are retained for 90 days without free-text messages. Details and rights are described in the privacy policy. The web uses only the technical session cookie hint_s (seven days) and the stored cookie choice; Android uses no cookies.

Terms of use, version 22 (English) · section “Lab report import and history” · also at /terms

Where the data are. At rest, the document stays only on your phone, wherever you keep it: PDFs and photos selected in Lab results are read and processed exclusively on the phone, and temporary copies are deleted after processing. In transit, the document never leaves the phone: only the report date and the results as printed (test, value, unit, reference interval) and a keyed fingerprint of the file travel, over HTTPS, an encrypted connection (TLS; Cloudflare uses TLS 1.3 when the phone supports it), each request also signed with a key kept on the phone, without name, surname, date of birth or any other reference to the person. On the server, only these are stored, linked to your pseudonymous account. They are pseudonymized, not anonymous: they carry no name, but they are linked to your account and remain health data under the GDPR and the Swiss FADP. The document on your phone, and the phone itself, remain your responsibility (screen lock, backups, apps you share it with). The results are saved automatically only when the whole document was read with certainty: one report date and every result line understood; otherwise nothing is saved. The same file, or the same test on the same date, is never saved twice. Only the test code or the test name as printed, value, unit, reference interval, report date and a keyed fingerprint of the file (used only to recognize the same file again) are stored with your account, also for an older report, until you delete them: a date on the web, a report in the app, all lab results on the web,

or your whole account. They are never deleted automatically, so your history stays complete; they are available on the web and on a replacement phone. A result outside the reference printed on the same report is shown in orange with an arrow: this compares numbers only and is not a medical assessment. You are responsible for selecting only your own reports, protecting your phone and checking the results against the original. Extraction may be incomplete or incorrect and does not provide medical interpretation. This responsibility does not exclude the provider's applicable obligations. Results are compared only within the same test and unit; no diagnosis or treatment recommendation is provided.

C04 Storage limitation Compliant

Requirement	Each kind of data kept only as long as its purpose needs
Law	GDPR Art. 5(1)(e) · FADP Art. 6(4)
Evidence	Blood pressure 365 days (nightly purge); lab results until the user deletes them (purpose: complete history, user-controlled); errors and events 90 days; sessions and links 7 days
Source document	docs/compliance/gdpr.md

Where it is declared to users

Terms of use, version 22 (English) · section "Account, storage and providers" · also at /terms

Sign in with Google uses OAuth 2.0/OpenID Connect. HINT 365 does not receive your Google password. The server stores an HMAC of your Google account identifier, not your email. Confirmed pressure readings are stored with your account in Cloudflare D1 in the EU for up to 365 days and purged daily; lab results stay until you delete them (never automatically). Both they are pseudonymized, not anonymous. Google recovery reconnects your synchronized history. Blood pressure is recorded by voice or with a photo of the monitor. The phone's speech service may use its own network processing. The photo Scan reads the monitor display with artificial intelligence. The Scan is an AI feature: it is on at once, free for 15 days from the first Scan, then with the AI features subscription; in every case at most 3 Scans a day. The trial is given once per Google account and per phone: for this the server keeps an HMAC fingerprint of the Google account and of the phone's identifier with the trial start date, also after the account is deleted, for at most 2 years and only for this purpose. The photo of the display goes through HINT 365's server to Anthropic (Claude), which reads the three numbers for HINT 365 and does not use them to train its models; the server passes the photo on without storing or logging it, and the photo carries no name or account. In every case the numbers read are shown to you and saved only if you confirm them, and the photo is then deleted from the phone. Only the three numbers you confirmed are stored by HINT 365. Acceptance records (pseudonymous account code, HMAC fingerprints of the Google account and of the phone, version, language and fingerprint of the text, date; never the email) are retained as evidence also after account deletion, with a backup copy in a second database in the EU; technical error codes are retained for 90 days without free-text messages. Details and rights are described in the privacy policy. The web uses only the technical session cookie hint_s (seven days) and the stored cookie choice; Android uses no cookies.

Terms of use, version 22 (English) · section "Lab report import and history" · also at /terms

Where the data are. At rest, the document stays only on your phone, wherever you keep it: PDFs and photos selected in Lab results are read and processed exclusively on the phone, and temporary copies are deleted after processing. In transit, the document never leaves the phone: only the report date and the results as printed (test, value, unit, reference interval) and a keyed fingerprint of the file travel, over HTTPS, an encrypted connection (TLS; Cloudflare uses TLS 1.3 when the phone supports it), each request also signed with a key kept on the phone, without name, surname, date of birth or any other reference to the person. On the server, only these are stored, linked to your pseudonymous account. They are pseudonymized, not anonymous: they carry no name, but they are linked to your account and remain health data under the GDPR and the Swiss FADP. The document on your phone, and the phone itself, remain your responsibility (screen lock, backups, apps you share it with). The results are saved automatically only when the whole document was read with certainty: one report date and every result line understood; otherwise nothing is saved. The same file, or the same test on the same date, is never saved twice. Only the test code or the test name as printed, value, unit, reference interval, report date and a keyed fingerprint of the file (used only to recognize the same file again) are stored with your account, also

for an older report, until you delete them: a date on the web, a report in the app, all lab results on the web, or your whole account. They are never deleted automatically, so your history stays complete; they are available on the web and on a replacement phone. A result outside the reference printed on the same report is shown in orange with an arrow: this compares numbers only and is not a medical assessment. You are responsible for selecting only your own reports, protecting your phone and checking the results against the original. Extraction may be incomplete or incorrect and does not provide medical interpretation. This responsibility does not exclude the provider's applicable obligations. Results are compared only within the same test and unit; no diagnosis or treatment recommendation is provided.

C05 Security in transit Compliant

Requirement	Encrypted transport and authenticated requests
Law	GDPR Art. 32 · FADP Art. 8
Evidence	HTTPS/TLS only (Cloudflare, TLS 1.3 when supported); every app request signed with a key kept on the phone; replay protection
Source document	docs/testing/test-report-2026-09-28.md

Where it is declared to users

Terms of use, version 22 (English) · section "Lab report import and history" · also at /terms

Where the data are. At rest, the document stays only on your phone, wherever you keep it: PDFs and photos selected in Lab results are read and processed exclusively on the phone, and temporary copies are deleted after processing. In transit, the document never leaves the phone: only the report date and the results as printed (test, value, unit, reference interval) and a keyed fingerprint of the file travel, over HTTPS, an encrypted connection (TLS; Cloudflare uses TLS 1.3 when the phone supports it), each request also signed with a key kept on the phone, without name, surname, date of birth or any other reference to the person. On the server, only these are stored, linked to your pseudonymous account. They are pseudonymized, not anonymous: they carry no name, but they are linked to your account and remain health data under the GDPR and the Swiss FADP. The document on your phone, and the phone itself, remain your responsibility (screen lock, backups, apps you share it with). The results are saved automatically only when the whole document was read with certainty: one report date and every result line understood; otherwise nothing is saved. The same file, or the same test on the same date, is never saved twice. Only the test code or the test name as printed, value, unit, reference interval, report date and a keyed fingerprint of the file (used only to recognize the same file again) are stored with your account, also for an older report, until you delete them: a date on the web, a report in the app, all lab results on the web, or your whole account. They are never deleted automatically, so your history stays complete; they are available on the web and on a replacement phone. A result outside the reference printed on the same report is shown in orange with an arrow: this compares numbers only and is not a medical assessment. You are responsible for selecting only your own reports, protecting your phone and checking the results against the original. Extraction may be incomplete or incorrect and does not provide medical interpretation. This responsibility does not exclude the provider's applicable obligations. Results are compared only within the same test and unit; no diagnosis or treatment recommendation is provided.

C06 Security at rest Partial

Requirement	Stored data protected against unauthorised access
Law	GDPR Art. 32 · FADP Art. 8
Evidence	Only the Worker reaches D1; the owner's Anthropic key for the Scan is a Worker secret (never in D1 or the repository); nobody adds an AI key of their own; codes, cookies, links and files as fingerprints. Health values are not field-encrypted and D1 disk encryption is not stated in Cloudflare's documentation we checked. The Scan trial is counted on HMAC fingerprints of the Google account and the phone (scan_trials), never an email or a raw id, kept at most 2 years after the account is deleted, only to prevent a second trial. The owner's powers (Admin console, versions, settings) work only from the owner's phone on record (owner_key); a new phone needs the owner's secret code (OWNER_CODE, 5 tries a day) or the GitHub workflow Owner phone. Acceptances of the terms are copied to a second EU database (personalhealthy-backup) at each acceptance and every night, as legal proof.
Next step	Decide whether to encrypt lab and pressure values per account
Source document	docs/compliance/gdpr.md

Where it is declared to users

Terms of use, version 22 (English) · section "Account, storage and providers" · also at /terms

Sign in with Google uses OAuth 2.0/OpenID Connect. HINT 365 does not receive your Google password. The server stores an HMAC of your Google account identifier, not your email. Confirmed pressure readings are stored with your account in Cloudflare D1 in the EU for up to 365 days and purged daily; lab results stay until you delete them (never automatically). Both they are pseudonymized, not anonymous. Google recovery reconnects your synchronized history. Blood pressure is recorded by voice or with a photo of the monitor. The phone's speech service may use its own network processing. The photo Scan reads the monitor display with artificial intelligence. The Scan is an AI feature: it is on at once, free for 15 days from the first Scan, then with the AI features subscription; in every case at most 3 Scans a day. The trial is given once per Google account and per phone: for this the server keeps an HMAC fingerprint of the Google account and of the phone's identifier with the trial start date, also after the account is deleted, for at most 2 years and only for this purpose. The photo of the display goes through HINT 365's server to Anthropic (Claude), which reads the three numbers for HINT 365 and does not use them to train its models; the server passes the photo on without storing or logging it, and the photo carries no name or account. In every case the numbers read are shown to you and saved only if you confirm them, and the photo is then deleted from the phone. Only the three numbers you confirmed are stored by HINT 365. Acceptance records (pseudonymous account code, HMAC fingerprints of the Google account and of the phone, version, language and fingerprint of the text, date; never the email) are retained as evidence also after account deletion, with a backup copy in a second database in the EU; technical error codes are retained for 90 days without free-text messages. Details and rights are described in the privacy policy. The web uses only the technical session cookie hint_s (seven days) and the stored cookie choice; Android uses no cookies.

C07 Data location

Partial

Requirement	Data stored in the EU
Law	GDPR Art. 44 · FADP Art. 16
Evidence	D1 database bound to the EU jurisdiction; the Worker may run at a Cloudflare edge outside the EU (stated in terms and privacy, gap G4)
Next step	Regional services (paid) if required after legal review
Source document	docs/compliance/gdpr.md

Where it is declared to users

Terms of use, version 22 (English) · section “Account, storage and providers” · also at /terms

Sign in with Google uses OAuth 2.0/OpenID Connect. HINT 365 does not receive your Google password. The server stores an HMAC of your Google account identifier, not your email. Confirmed pressure readings are stored with your account in Cloudflare D1 in the EU for up to 365 days and purged daily; lab results stay until you delete them (never automatically). Both they are pseudonymized, not anonymous. Google recovery reconnects your synchronized history. Blood pressure is recorded by voice or with a photo of the monitor. The phone’s speech service may use its own network processing. The photo Scan reads the monitor display with artificial intelligence. The Scan is an AI feature: it is on at once, free for 15 days from the first Scan, then with the AI features subscription; in every case at most 3 Scans a day. The trial is given once per Google account and per phone: for this the server keeps an HMAC fingerprint of the Google account and of the phone’s identifier with the trial start date, also after the account is deleted, for at most 2 years and only for this purpose. The photo of the display goes through HINT 365’s server to Anthropic (Claude), which reads the three numbers for HINT 365 and does not use them to train its models; the server passes the photo on without storing or logging it, and the photo carries no name or account. In every case the numbers read are shown to you and saved only if you confirm them, and the photo is then deleted from the phone. Only the three numbers you confirmed are stored by HINT 365. Acceptance records (pseudonymous account code, HMAC fingerprints of the Google account and of the phone, version, language and fingerprint of the text, date; never the email) are retained as evidence also after account deletion, with a backup copy in a second database in the EU; technical error codes are retained for 90 days without free-text messages. Details and rights are described in the privacy policy. The web uses only the technical session cookie hint_s (seven days) and the stored cookie choice; Android uses no cookies.

C08 Transfers outside EU/CH Partial

Requirement	Transfers named, with safeguards
Law	GDPR Art. 13(1)(f), 44–49 · FADP Art. 16
Evidence	Google (sign-in, billing) and Anthropic (photo Scan, terms v21) outside the EU, named with DPF/SCC. The Scan (15-day trial, then the 4.99 USD AI features subscription; 3 a day, at most 2.50 USD of AI per person a year, tracked in scan_usage; Claude Haiku 4.5) sends the photo of the display alone through the Worker to Anthropic, which reads it as processor and does not train on it; the Worker neither stores nor logs it. Only the three confirmed numbers are stored; lab documents are never transferred
Next step	Accept Anthropic's commercial terms and DPA on the owner's account; legal review of the wording (G3)
Source document	docs/compliance/gdpr.md

Where it is declared to users

Terms of use, version 22 (English) · section “Account, storage and providers” · also at /terms

Sign in with Google uses OAuth 2.0/OpenID Connect. HINT 365 does not receive your Google password. The server stores an HMAC of your Google account identifier, not your email. Confirmed pressure readings are stored with your account in Cloudflare D1 in the EU for up to 365 days and purged daily; lab results stay until you delete them (never automatically). Both they are pseudonymized, not anonymous. Google recovery reconnects your synchronized history. Blood pressure is recorded by voice or with a photo of the monitor. The phone's speech service may use its own network processing. The photo Scan reads the monitor display with artificial intelligence. The Scan is an AI feature: it is on at once, free for 15 days from the first Scan, then with the AI features subscription; in every case at most 3 Scans a day. The trial is given once per Google account and per phone: for this the server keeps an HMAC fingerprint of the Google account and of the phone's identifier with the trial start date, also after the account is deleted, for at most 2 years and only for this purpose. The photo of the display goes through HINT 365's server to Anthropic (Claude), which reads the three numbers for HINT 365 and does not use them to train its models; the server passes the photo on without storing or logging it, and the photo carries no name or account. In every case the numbers read are shown to you and saved only if you confirm them, and the photo is then deleted from the phone. Only the three numbers you confirmed are stored by HINT 365. Acceptance records (pseudonymous account code, HMAC fingerprints of the Google account and of the phone, version, language and fingerprint of the text, date; never the email) are retained as evidence also after account deletion, with a backup copy in a second database in the EU; technical error codes are retained for 90 days without free-text messages. Details and rights are described in the privacy policy. The web uses only the technical session cookie hint_s (seven days) and the stored cookie choice; Android uses no cookies.

C09 Processors Open

Requirement	Processor agreements checked and filed
Law	GDPR Art. 28 · FADP Art. 9
Evidence	Gap G11: Cloudflare DPA acceptance on the account not yet confirmed
Next step	Human confirms in the Cloudflare account
Source document	docs/compliance/gdpr.md

Not declared to users: an internal control, still open.

C10 Rights: access and portability Partial

Requirement	Full export of one's data
Law	GDPR Art. 15, 20 · FADP Art. 25, 28
Evidence	Web Dashboard shows all data, PDF of lab results and 7-day pressure report; no single machine-readable export of everything (G5)
Next step	"Download all my data" (JSON/CSV) in the Web Dashboard
Source document	docs/compliance/gdpr.md

Where it is declared to users

Terms of use, version 22 (English) · section "Availability, responsibility and acceptance" · also at /terms

The service may have outages and require updates. Unsupported app versions may be disabled for security. Nothing in these terms excludes statutory rights or the provider's mandatory responsibilities. You can delete individual records or your account in the app, and exercise the rights explained in the privacy policy. You can download these terms as a PDF from the app, with the button at the end of the text, and keep them. By accepting, you confirm you are at least 18 and agree to these terms. Consent to storing your health data is requested separately and can be withdrawn by deleting your account. Acceptance and health-data consent are recorded with account, document version, language, text hash, app version and time.

C11 Rights: erasure Compliant

Requirement	Delete single data, all data, the account
Law	GDPR Art. 17 · FADP Art. 32
Evidence	Readings, a lab date, all lab results, a report, or the whole account, immediately; acceptance record kept on legitimate interest
Source document	docs/compliance/gdpr.md

Where it is declared to users

Terms of use, version 22 (English) · section “Availability, responsibility and acceptance” · also at /terms

The service may have outages and require updates. Unsupported app versions may be disabled for security. Nothing in these terms excludes statutory rights or the provider’s mandatory responsibilities. You can delete individual records or your account in the app, and exercise the rights explained in the privacy policy. You can download these terms as a PDF from the app, with the button at the end of the text, and keep them. By accepting, you confirm you are at least 18 and agree to these terms. Consent to storing your health data is requested separately and can be withdrawn by deleting your account. Acceptance and health-data consent are recorded with account, document version, language, text hash, app version and time.

Terms of use, version 22 (English) · section “Lab report import and history” · also at /terms

Where the data are. At rest, the document stays only on your phone, wherever you keep it: PDFs and photos selected in Lab results are read and processed exclusively on the phone, and temporary copies are deleted after processing. In transit, the document never leaves the phone: only the report date and the results as printed (test, value, unit, reference interval) and a keyed fingerprint of the file travel, over HTTPS, an encrypted connection (TLS; Cloudflare uses TLS 1.3 when the phone supports it), each request also signed with a key kept on the phone, without name, surname, date of birth or any other reference to the person. On the server, only these are stored, linked to your pseudonymous account. They are pseudonymized, not anonymous: they carry no name, but they are linked to your account and remain health data under the GDPR and the Swiss FADP. The document on your phone, and the phone itself, remain your responsibility (screen lock, backups, apps you share it with). The results are saved automatically only when the whole document was read with certainty: one report date and every result line understood; otherwise nothing is saved. The same file, or the same test on the same date, is never saved twice. Only the test code or the test name as printed, value, unit, reference interval, report date and a keyed fingerprint of the file (used only to recognize the same file again) are stored with your account, also for an older report, until you delete them: a date on the web, a report in the app, all lab results on the web, or your whole account. They are never deleted automatically, so your history stays complete; they are available on the web and on a replacement phone. A result outside the reference printed on the same report is shown in orange with an arrow: this compares numbers only and is not a medical assessment. You are responsible for selecting only your own reports, protecting your phone and checking the results against the original. Extraction may be incomplete or incorrect and does not provide medical interpretation. This responsibility does not exclude the provider’s applicable obligations. Results are compared only within the same test and unit; no diagnosis or treatment recommendation is provided.

C12 Records Partial

Requirement	Record of processing activities
Law	GDPR Art. 30 · FADP Art. 12
Evidence	Draft kept in docs/compliance/gdpr.md section 5, updated with lab results
Next step	Human reviews and signs
Source document	docs/compliance/gdpr.md

Not declared to users: an internal control.

C13 Impact assessment Open

Requirement	DPIA for health data at scale
Law	GDPR Art. 35 · FADP Art. 22
Evidence	Gap G9
Next step	Claude drafts from the threat model, Human signs
Source document	docs/compliance/gdpr.md

Not declared to users: an internal control, still open.

C14 Breach procedure Open

Requirement	Notify the authority within 72 hours, users if high risk
Law	GDPR Art. 33, 34 · FADP Art. 24
Evidence	Gap G10; emergency switch-off of all apps exists (app_off)
Next step	One-page procedure (who notices, decides, notifies FDPIC / Garante)
Source document	docs/security/vulnerability-management.md

Not declared to users: an internal control, still open.

C15 EU representative Open

Requirement	Representative in the EU for a Swiss controller
Law	GDPR Art. 27
Evidence	Gap G7
Next step	Human appoints a representative service
Source document	docs/compliance/gdpr.md

Not declared to users: an internal control, still open.

C16 Cookies Compliant

Requirement	Only technical cookies, after consent, declared
Law	ePrivacy Art. 5(3) · FADP
Evidence	One cookie (hint_s) after consent; the app uses none; declared in terms and privacy
Source document	docs/legal/privacy.html

Where it is declared to users

Terms of use, version 22 (English) · section "Account, storage and providers" · also at /terms

Sign in with Google uses OAuth 2.0/OpenID Connect. HINT 365 does not receive your Google password. The server stores an HMAC of your Google account identifier, not your email. Confirmed pressure readings are stored with your account in Cloudflare D1 in the EU for up to 365 days and purged daily; lab results stay until you delete them (never automatically). Both they are pseudonymized, not anonymous. Google recovery reconnects your synchronized history. Blood pressure is recorded by voice or with a photo of the monitor. The phone's speech service may use its own network processing. The photo Scan reads the monitor display with artificial intelligence. The Scan is an AI feature: it is on at once, free for 15 days from the first Scan, then with the AI features subscription; in every case at most 3 Scans a day. The trial is given once per Google account and per phone: for this the server keeps an HMAC fingerprint of the Google account and of the phone's identifier with the trial start date, also after the account is deleted, for at most 2 years and only for this purpose. The photo of the display goes through HINT 365's server to Anthropic (Claude), which reads the three numbers for HINT 365 and does not use them to train its models; the server passes the photo on without storing or logging it, and the photo carries no name or account. In every case the numbers read are shown to you and saved only if you confirm them, and the photo is then deleted from the phone. Only the three numbers you confirmed are stored by HINT 365. Acceptance records (pseudonymous account code, HMAC fingerprints of the Google account and of the phone, version, language and fingerprint of the text, date; never the email) are retained as evidence also after account deletion, with a backup copy in a second database in the EU; technical error codes are retained for 90 days without free-text messages. Details and rights are described in the privacy policy. The web uses only the technical session cookie hint_s (seven days) and the stored cookie choice; Android uses no cookies.

C17 Privacy by design Compliant

Requirement	The owner never sees values, reports or names
Law	GDPR Art. 25 · FADP Art. 7
Evidence	Admin shows totals and codes only; observability without values
Source document	docs/architecture/architecture.html

Not declared to users: an internal control.

C18 Medical device boundary Partial

Requirement	No diagnosis or interpretation
Law	EU MDR / Swiss MedDO (MDCG 2019-11)
Evidence	No judgement or advice; the orange ↑/↓ only repeats the comparison with the reference printed on the report
Next step	Legal review before the Play Store
Source document	docs/compliance/gdpr.md

Where it is declared to users

Terms of use, version 22 (English) · section "Purpose and medical limits" · also at /terms

HINT 365 is NOT a medical device and is not a health service. It is only a digital record of the data you enter, under your sole responsibility: the accuracy and completeness of the data are yours. HINT 365 does not measure anything, does not diagnose, gives no advice, instructions or recommendations of any kind, does not judge whether a value is normal or abnormal, and in no way replaces your doctor. Do not make any decision about your health based on the app. Never stop, suspend or change treatments, therapies or medicines agreed with your doctor because of the app. Always consult your doctor for every decision or action concerning your health. In an emergency call a doctor or emergency services at once (144 in Switzerland, 112 in Europe). The owner is not liable for decisions taken on the basis of the data shown by the app.

Terms of use, version 22 (English) · section "Lab report import and history" · also at /terms

Where the data are. At rest, the document stays only on your phone, wherever you keep it: PDFs and photos selected in Lab results are read and processed exclusively on the phone, and temporary copies are deleted after processing. In transit, the document never leaves the phone: only the report date and the results as printed (test, value, unit, reference interval) and a keyed fingerprint of the file travel, over HTTPS, an encrypted connection (TLS; Cloudflare uses TLS 1.3 when the phone supports it), each request also signed with a key kept on the phone, without name, surname, date of birth or any other reference to the person. On the server, only these are stored, linked to your pseudonymous account. They are pseudonymized, not anonymous: they carry no name, but they are linked to your account and remain health data under the GDPR and the Swiss FADP. The document on your phone, and the phone itself, remain your responsibility (screen lock, backups, apps you share it with). The results are saved automatically only when the whole document was read with certainty: one report date and every result line understood; otherwise nothing is saved. The same file, or the same test on the same date, is never saved twice. Only the test code or the test name as printed, value, unit, reference interval, report date and a keyed fingerprint of the file (used only to recognize the same file again) are stored with your account, also for an older report, until you delete them: a date on the web, a report in the app, all lab results on the web, or your whole account. They are never deleted automatically, so your history stays complete; they are available on the web and on a replacement phone. A result outside the reference printed on the same report is shown in orange with an arrow: this compares numbers only and is not a medical assessment. You are responsible for selecting only your own reports, protecting your phone and checking the results against the original. Extraction may be incomplete or incorrect and does not provide medical interpretation. This responsibility does not exclude the provider's applicable obligations. Results are compared only within the same test and unit; no diagnosis or treatment recommendation is provided.

C19 Vulnerability management

Compliant

Requirement	Known vulnerabilities found and fixed in time
Law	GDPR Art. 32 · FADP Art. 8
Evidence	Nightly OSV/Semgrep/gitleaks scan, Dependabot, deadlines by severity; see the Security console
Source document	docs/security/vulnerability-management.md

Not declared to users: an internal control.